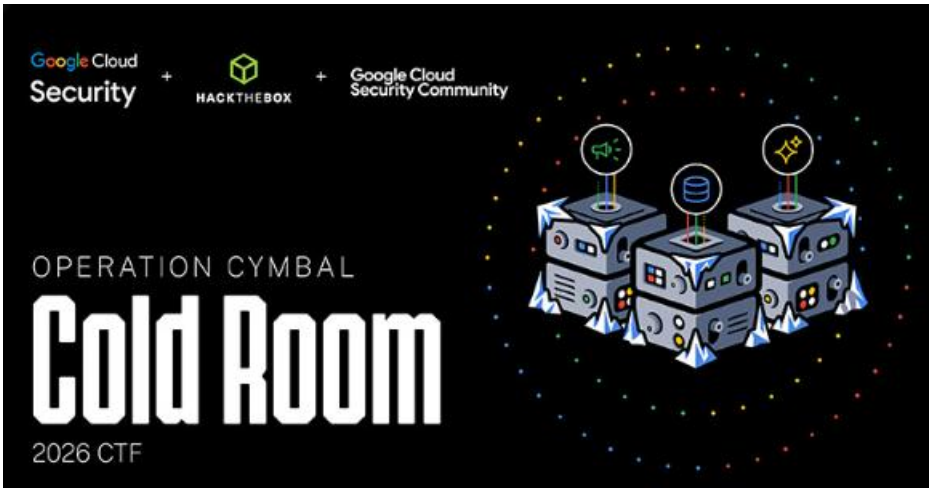
WRITE-UP

Operation Cymbal: Cold Room



X



By Beixuan

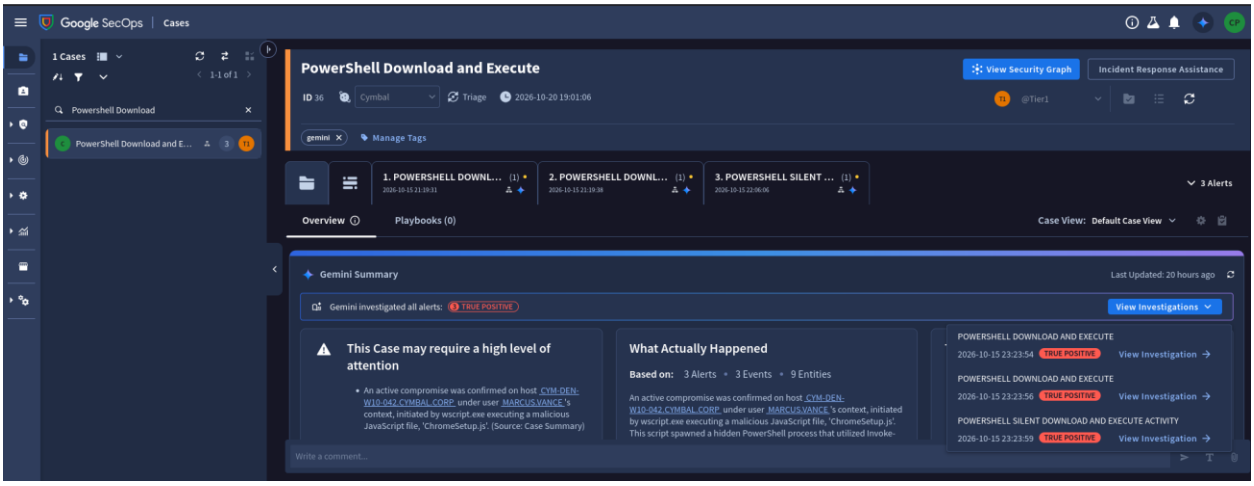
Deceptive Click

Welcome to the Cymbal Investments Security Operations Center. A high-priority case titled "PowerShell Download And Execute" has just landed in your queue after Curated Detections flagged suspicious activity originating from an endpoint in the Denver office. Leveraging the full power of Google SecOps, from lightning-fast SIEM search and Gemini-assisted investigations to frontline adversary context in Google Threat Intelligence, your mission is to trace the intrusion back to its initial point of entry, and and uncover the adversary's ultimate objectives before critical corporate assets are compromised.

Q1. What is the hostname of the compromised endpoint in the Denver office? (expected format: FAKE-HOST-NAME-000.false.name)

Pada tahap awal ini, kita diminta mencari Hostname endpoint yang terinfeksi di Denver.

Disini kita tinggal mencari di search case terkait Powershell Download, eht tiba tiba ada gemini yang memberi summary, disitu ada host yang telah dikonfirmasi berbahaya dan ternyata itu flagnya.



Flag1: CYM-DEN-W10-042.cymbal.corp

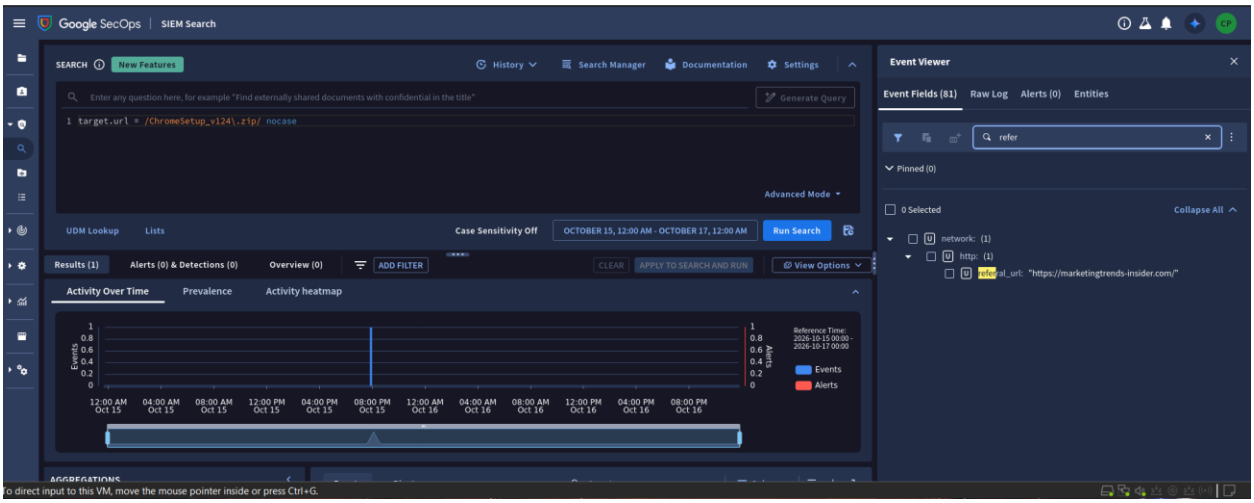
Q2. The GTI Malware Profile states that FAKEUPDATES is delivered via compromised third-party websites injecting malicious JavaScript. By analyzing web proxy logs around the time of the download, what is the domain of the compromised blog that served as the referer for the malicious update archive? (expected format: domainname.com)

Pada Q2 ini kita diminta mencari Domain blog yang disusupi, kita pindah ke Investigation dan SIEM search.

Query:

```
target.url = /ChromeSetup_v124\.zip/ nocase
```

dengan query tersebut kita mencari request yang mengunduh archieve update, kemudian pada event viewer bisa dilihat refereal url, disitu terdapat domain yang telah disusupi dan itu flagnya.



Flag2: marketingtrends-insider.com

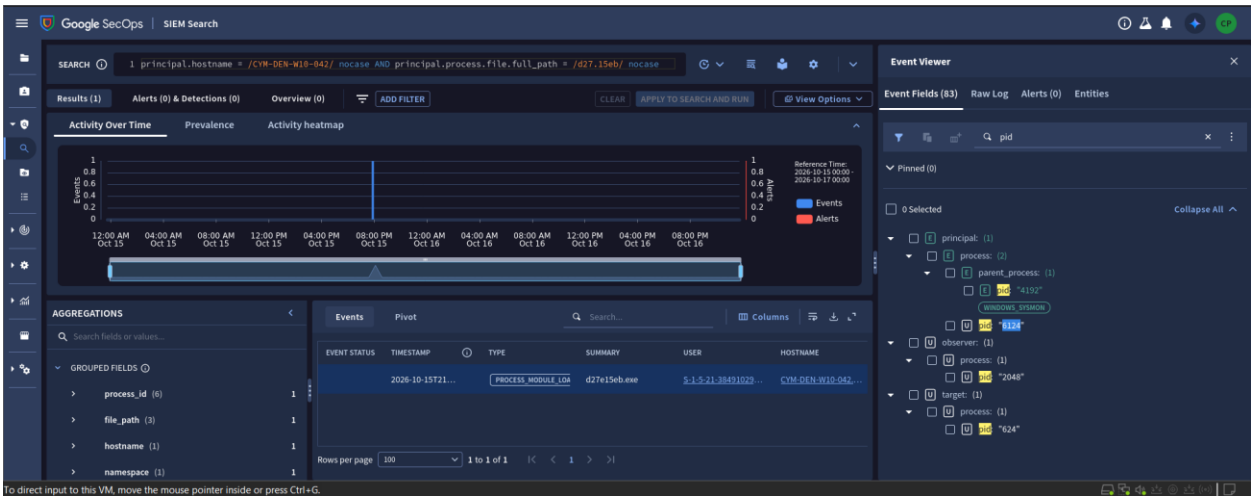
Q3. The secondary payload d27e15eb.exe achieved privilege elevation by hollowing into a SYSTEM process. What was the Target Process ID of the specific svchost.exe instance injected into on the compromised endpoint? (expected format: 000)

Pada Q3 kita mencari PID svchost.exe yang di-hollow

Query:

```
principal.hostname = /CYM-DEN-W10-042/ nocase AND principal.process.file.full_path = /d27.15eb/ nocase
```

dari query tersebut terdapat 1 event, lalu kita cek lognya untuk mencari PID terdapat 4 PID tetapi karena formatnya hanya 3 angka jadinya kita ambil yang PID berisi 3 angka yaitu 624, jadi flagnya itu.



Flag3: 624

Q4. Following domain reconnaissance, the adversary conducted Kerberoasting against the Domain Controller (CYM-DC-01) to harvest service credentials. What is the full Service Principal Name (SPN) requested in the Kerberos TGS ticket? (expected format: XXXXXXX/FAKE-HOST-NAME-00.false.name:0000)

Pada Q4 terkait SPN yang diminta saat Kerberoasting,

Kerberoasting adalah teknik meminta tiket layanan Kerberos (TGS) untuk akun service, lalu meng-crack tiket itu secara offline untuk mendapatkan password akunnya. Permintaan TGS tercatat di domain controller sebagai Windows Event ID 4769.

Query 1:

```
principal.hostname = /CYM-DC-01/ nocase AND metadata.product_event_type = "4769"
```

saat menggunakan query tersebut event yang ditampilkan 0 kemudian aku cek lagi dengan guqery ini

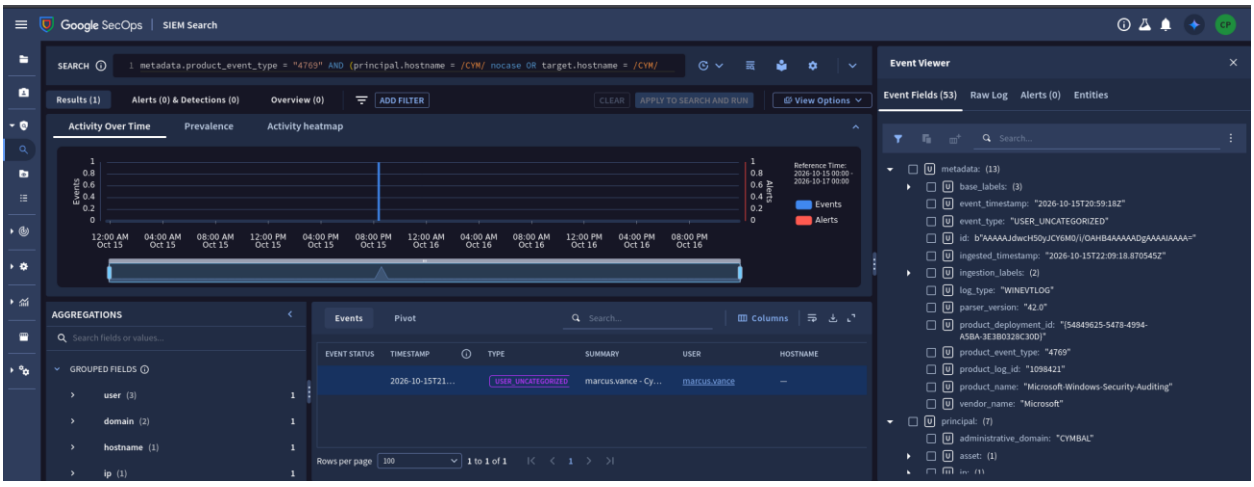
Query 2:

```
metadata.product_event_type = "4769"
```

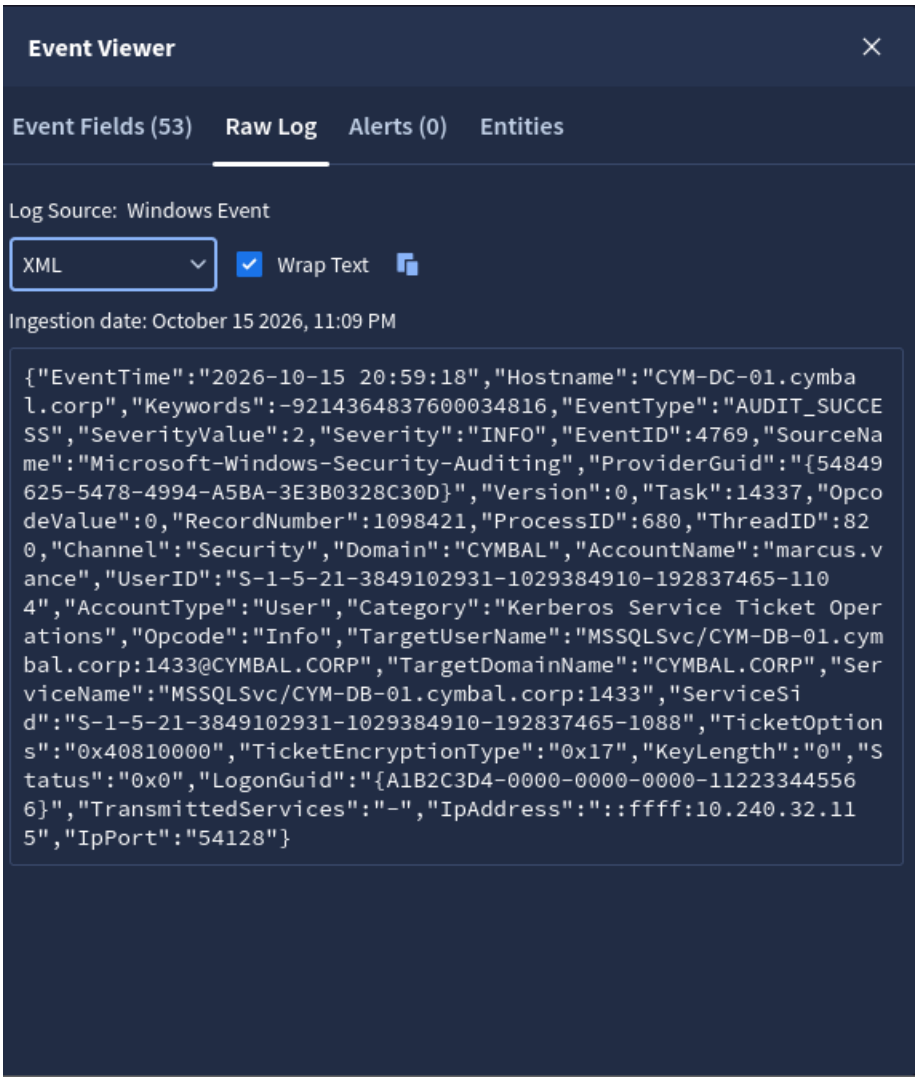
dari query tersebut muncul 78 Events, ini sangat menghabiskan waktu jika harus mencari satu-satu di events tersebut. Solusinya membuat query yang lebih spesifik.

Query 3:

```
metadata.product_event_type = "4769" AND (principal.hostname = /CYM/ nocase
OR target.hostname = /CYM/ nocase OR principal.user.userid = /marcus/ nocase OR target.user.userid = /marcus/ nocase)
```



Kita cek Raw log nya agar lebih lengkap dan disana ada Servicename, itulah flagnya.



Flag4: MSSQLSvc/CYM-DB-01.cymbal.corp:1433

Q5. Our threat hunting reveals the attacker switched identities using a cracked Kerberos service account. What username was used for subsequent lateral movement? (expected format: username)

Pada Q5 ini terkait Akun service yang dipakai untuk lateral movement

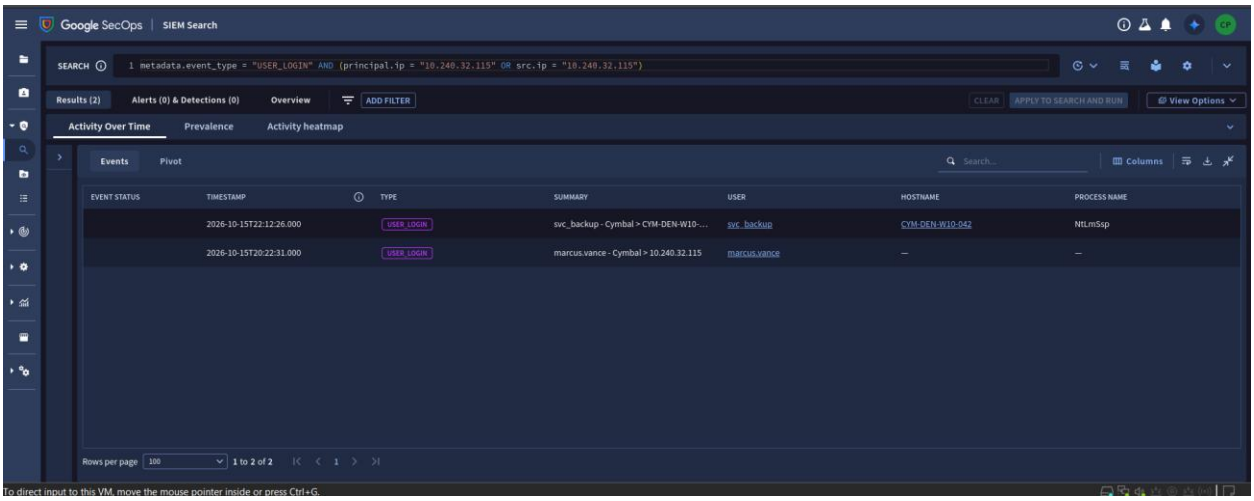
Setelah password akun service berhasil di-crack, penyerang memakainya untuk login ke server lain dari komputer korban. Jadi kita mencari login dari IP komputer Denver.

Query:

```
metadata.event_type = "USER_LOGIN" AND (principal.ip = "10.240.32.115" OR src.ip = "10.240.32.115")
```

hasil dari query tersebut menampilkan 2 events yang Dimana salah satunya flagnya, kita bisa mengecek di events terdapat user marcus.vence dan svc_backup, login dari marcus.vence ternyata

login normal korban sebelum kerberoasting sedangka svc_backup merupakan login jaringan (NtLmSsp) setelah Kerberoasting, jadi flagnya Adalah svc_backup



Flag5: svc_backup

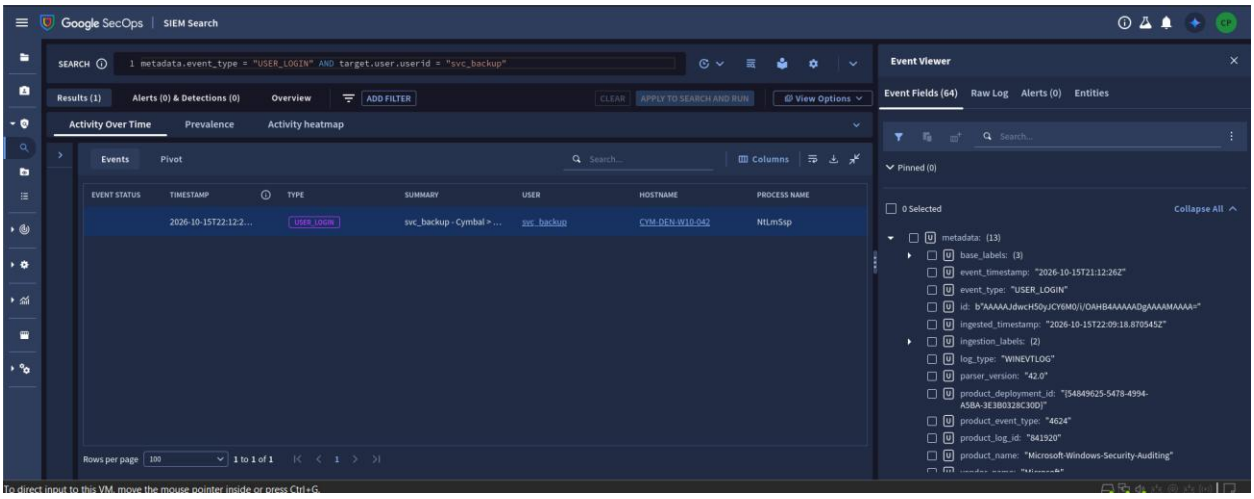
Q6. What is the file name of the compressed zip archive created by the attacker on the file server to stage sensitive financial audit files? (expected format: File_Name.extension)

Pada Q6 ini terkait Nama file zip di file server, Setelah masuk ke CYM-FS-01, langkah attacker berikutnya adalah mengumpulkan dan mengemas data sebelum dicuri.

Query:

```
metadata.event_type = "USER_LOGIN" AND target.user.userid = "svc_backup"
```

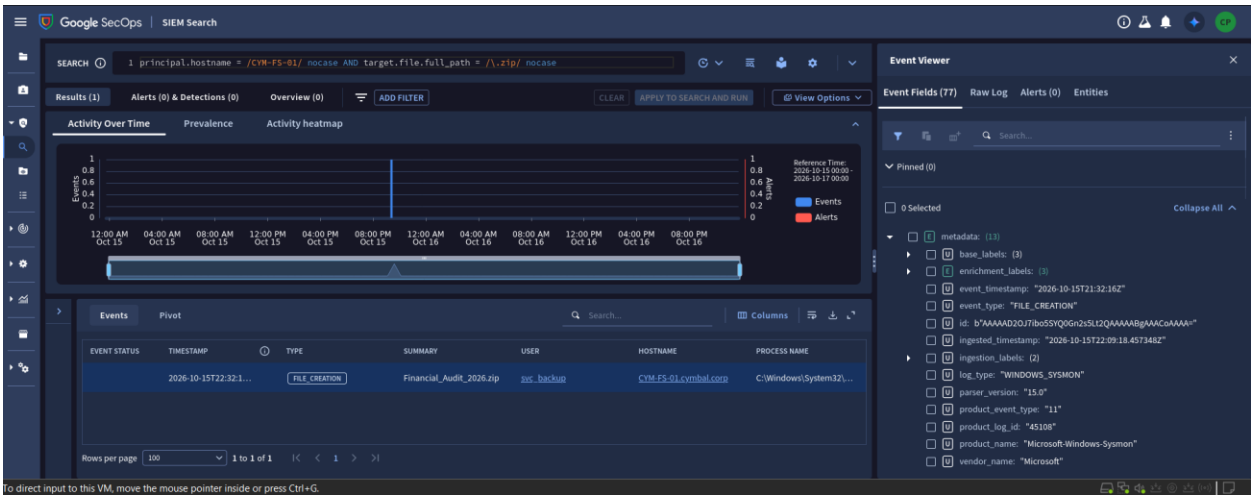
dari query diatas bisa dilihat log yang muncul Cuma 1, setelah itu kita cek ternyata log ini menunjukkan svc_backup login ke sana lewat jaringan (LogonType 3, NTLM) dari komputer Denver (CYM-DEN-W10-042, IP 10.240.32.115).



Query:

```
principal.hostname = /CYM-FS-01/ nocase AND target.file.full_path = /\.zip/ nocase
```

dengan query diatas muncul 1 log yang Dimana itu usernya svc_backup dan terdapat sebuah file yang dibuat, file tersebut kemungkinan file yang akan dicuri dan ternyata benar. File tersebut Adalah flagnya.



Flag6: Financial_Audit_2025.zip

OAuth Heist

Welcome to the Cymbal Investments Security Operations Center. A high-priority threat bulletin from Google Threat Intelligence covering SHINYHUNTERS has landed in your Emerging Threats. Leveraging the full power of Google SecOps, from SIEM search and Curated Detections to Google Threat Intelligence (GTI) adversary reporting, your mission is to investigate the initial identity compromise and uncover the full scope of the incident.

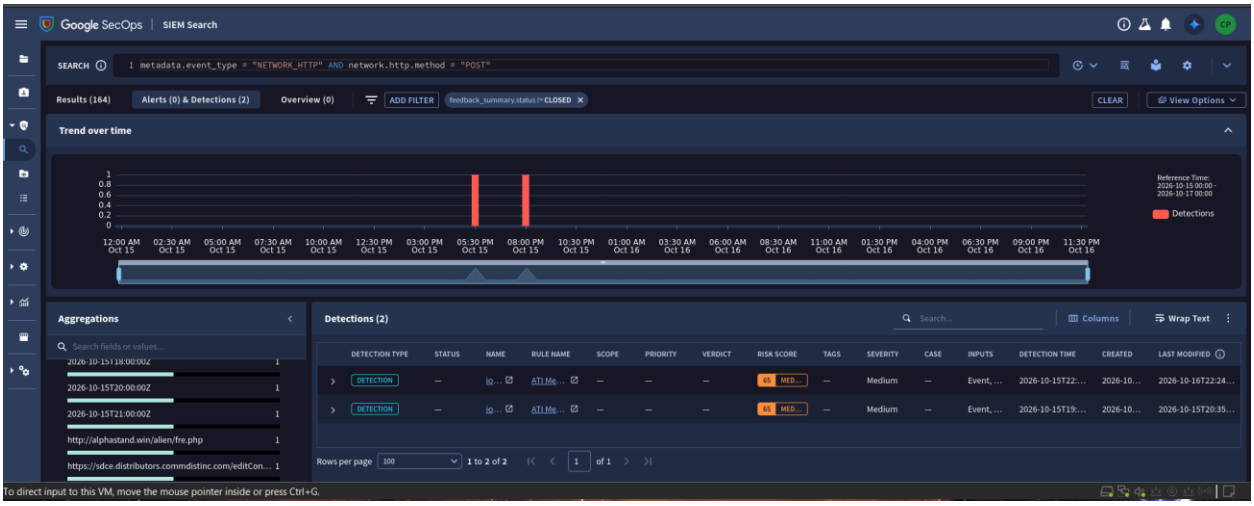
Q1. What is the phishing domain where employee credentials were submitted via an HTTP POST request? (expected format: domainname.com)

Pertanyaan untuk Q1 itu terkait domain phising, kita diminta mencari domain tersebut

Query:

```
metadata.event_type = "NETWORK_HTTP" AND network.http.method = "POST"
```

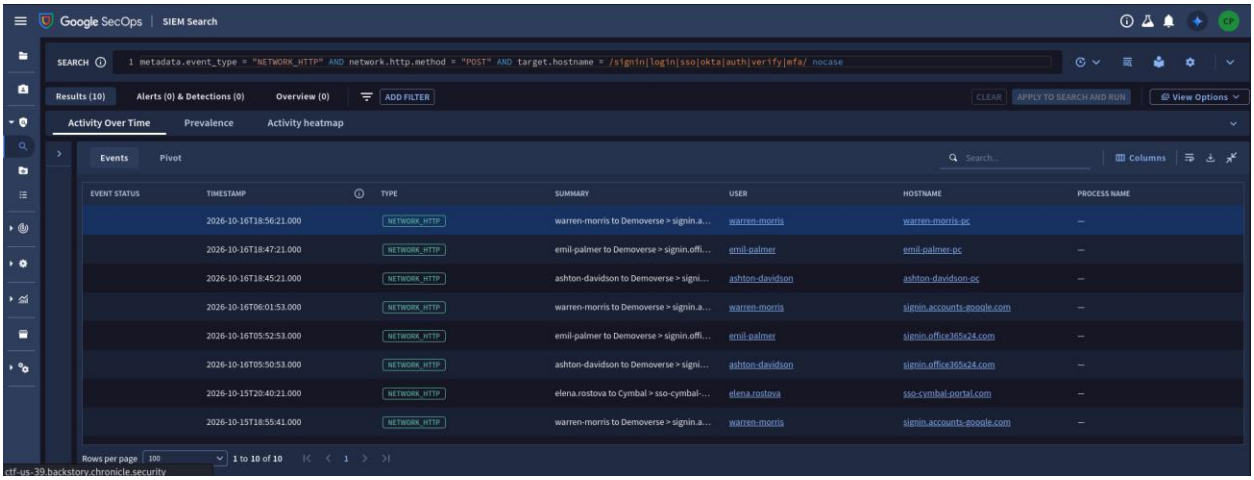
dari query tersebut hanya 2 detection, kemudian lihat aggregations dipinggir, disitu ada 2 domain tetapi sayangnya bukan itu.



Query:

```
metadata.event_type = "NETWORK_HTTP" AND network.http.method = "POST"
AND target.hostname = /signin|login|sso|okta|auth|verify|mfa/ nocase
```

disini kita membuat query yang spesifik, kemudian terlihat ada 10 events, kuncinya lihat di summary, semua baris bertuliskan to Demoverse yang berarti itu domain milik organisasi, dan asa satu domain yang arahnya ke sso, dan itulah flagnya.



Flag1: sso-cymbal-portal.com

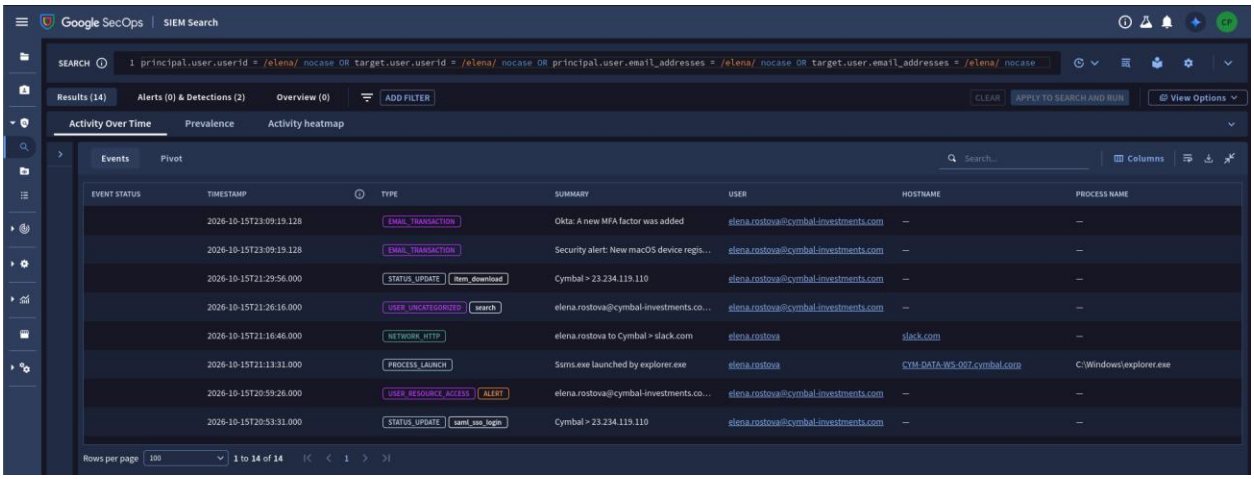
Q2. To prevent the compromised employee from noticing the persistence mechanism, the adversary abused a newly authorized third-party OAuth application to permanently purge security notifications from the victim's inbox. What is the exact subject line of the first permanently deleted email, which alerted on multi-factor authentication changes? (expected format: Hello! This is a fake email subject line).

Pertanyaan kedua ini terkait email MFA yang dihapus permanen.

Query:

```
metadata.product_event_type = /authorize|oauth|token|grant/ nocase AND (principal.user.email_addresses = /elena/ nocase
OR target.user.email_addresses = /elena/ nocase OR principal.user.userid = /elena/ nocase)
```

karena dari sebelumnya terdapat nama elena, kita cari target email elena, dan muncul TYPE EMAIL_TRANSACTION, disitu ada summary terdapat pembahasan terkait MFA baru yang ditambahkan, dan ternyata itu flagnya.

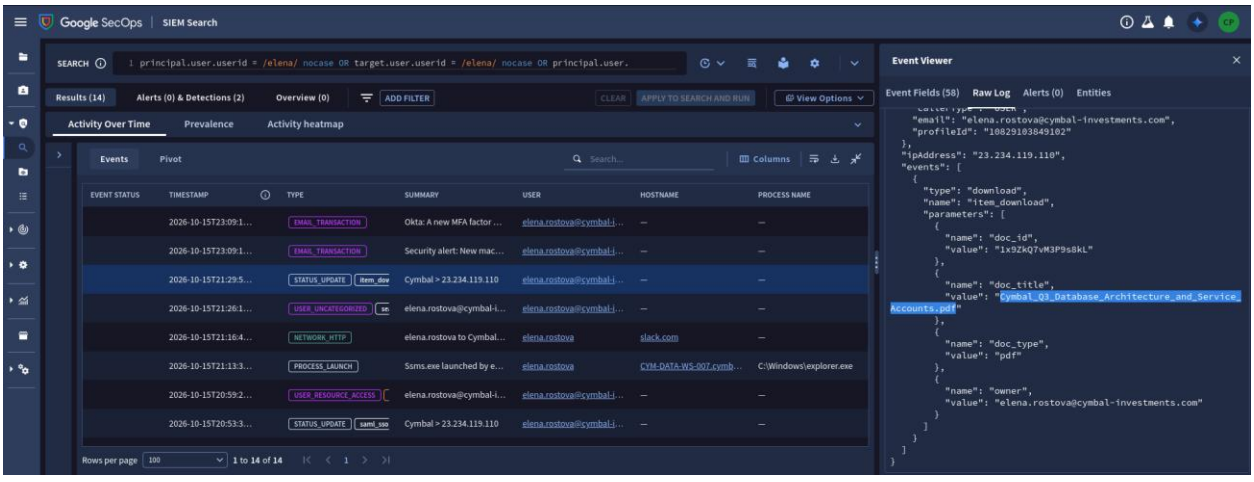


Flag2: Okta: A new MFA factor was added

Q3. Continuing to monitor the compromised employee's cloud activity from the attacker's proxy infrastructure, what sensitive internal document did the adversary locate and download? (expected format: File_Name.extension)

Pada Q3 ini ditanya terkait file yang diunduh attacker dari cloud lewat infrastruktur proxy-nya

Query yang digunakan sama dengan Q2, disini terlihat dari semua event elena kita harus membedakan mana event elena sendiri dan aktivitas hacker. Pada events tersebut ada satu event yang Dimana itu event item download, jadi kita cek log tersebut, dan mendapatkan flagnya.



Flag3: Cymbal_Q3_Database_Architecture_and_Service_Accounts.pdf

Q4. Armed with credentials discovered in the stolen document, what privileged service account did the attacker authenticate to from the compromised employee's workstation to access the internal database server? (expected format: username)

Pada Q4 ini, ditanya terkait akun service yang dipakai attacker untuk masuk ke server database dari workstation korban.

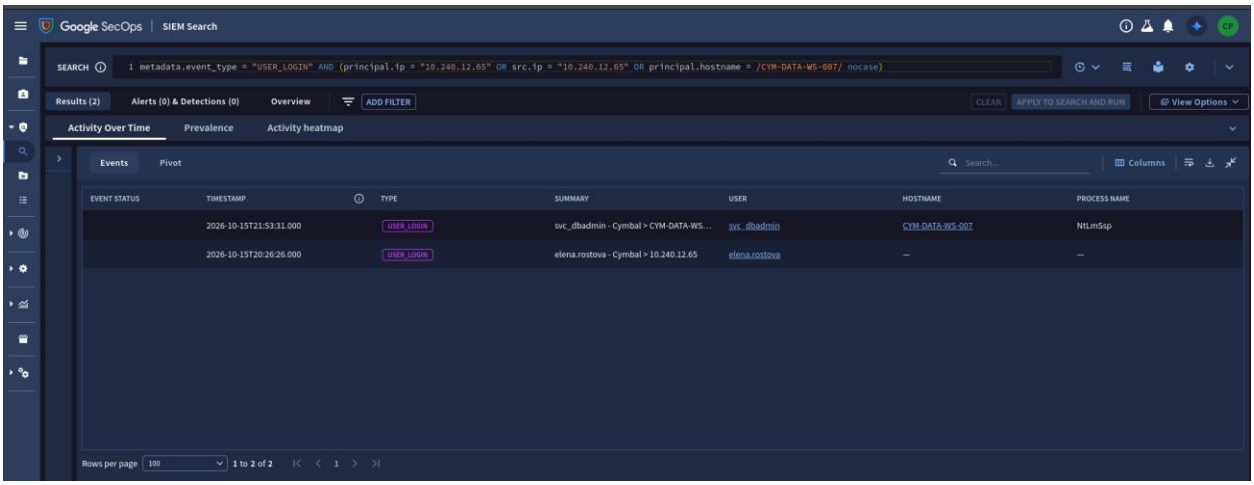
Disini terdapat jebakan jika kita mencari query terkait elena, kita tidak akan menemukan login tersebut karena itu menggunakan nama akun lain.

Solusinya pivot user ke host/IP

Query:

```
metadata.event_type = "USER_LOGIN" AND (principal.ip = "10.240.12.65" OR src.ip = "10.240.12.65"
OR principal.hostname = /CYM-DATA-WS-007/ nocase)
```

setelah menggunakan query diatas dapat dilihat terdapat USER yang melakukan login, dan itu flagnya



Flag4: svc_dbadmin

Q5. Once authenticated to that internal server, what is the file name of the raw database dump exported by the attacker prior to compressing it into an archive? (expected format: file_name.extension)

Pada Q5 ini yang ditanya terkait file database dump

Pivot ke semua aktivitas svc_dbadmin dengan menggunakan query ini.

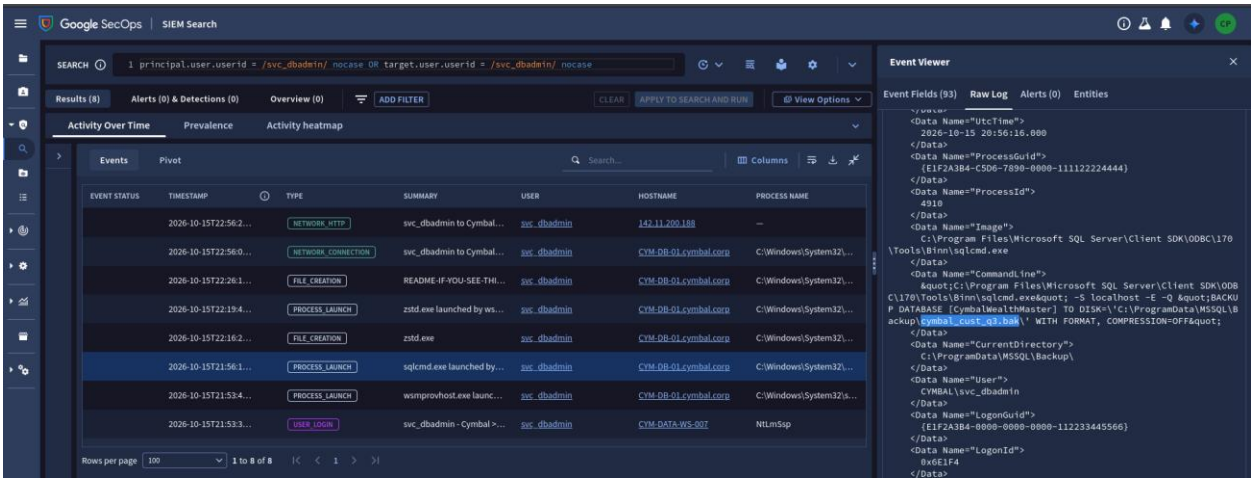
Query:

```
principal.user.userid = /svc_dbadmin/ nocase OR target.user.userid = /svc_dbadmin/ nocase
```

Hasilnya 8 event, semuanya di server CYM-DB-01, Urutan eventnya menceritakan alurnya:

wsmprovhost.exe (attacker masuk lewat PowerShell Remoting), lalu sqlcmd.exe (dump), zstd.exe (kompresi), dan terakhir koneksi jaringan keluar (eksfiltrasi).

Disini bisa dicek pada event terdapat sebuah file backup, itu flagnya



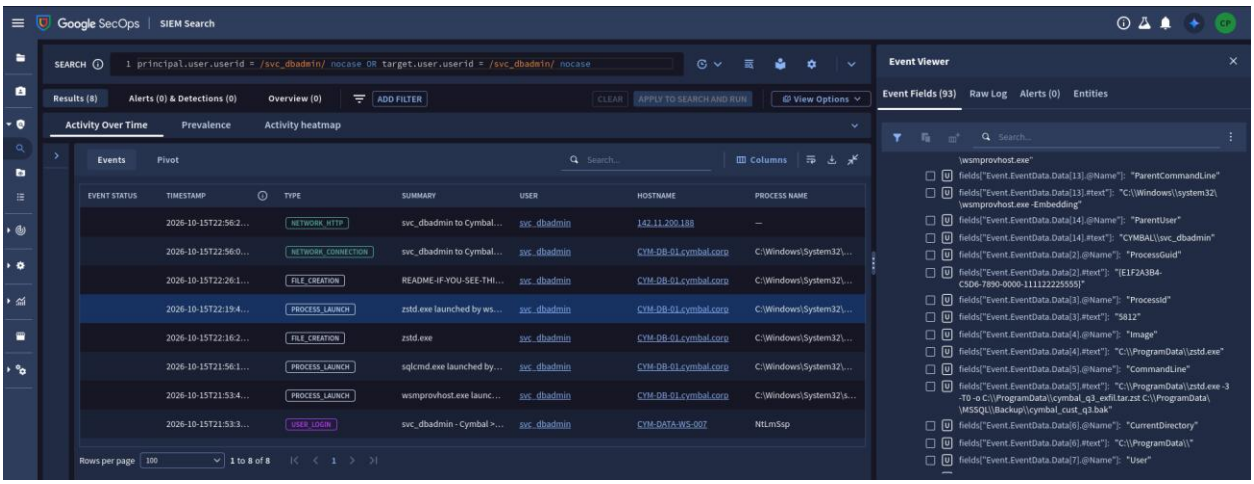
Flag5: cymbal_cust_q3.bak

Q6. What is the full exfiltration URL (including destination IP and port) used by the attacker to transfer the compressed archive? (expected format: http://8.8.8.8:0000/path/file_name.extensions)

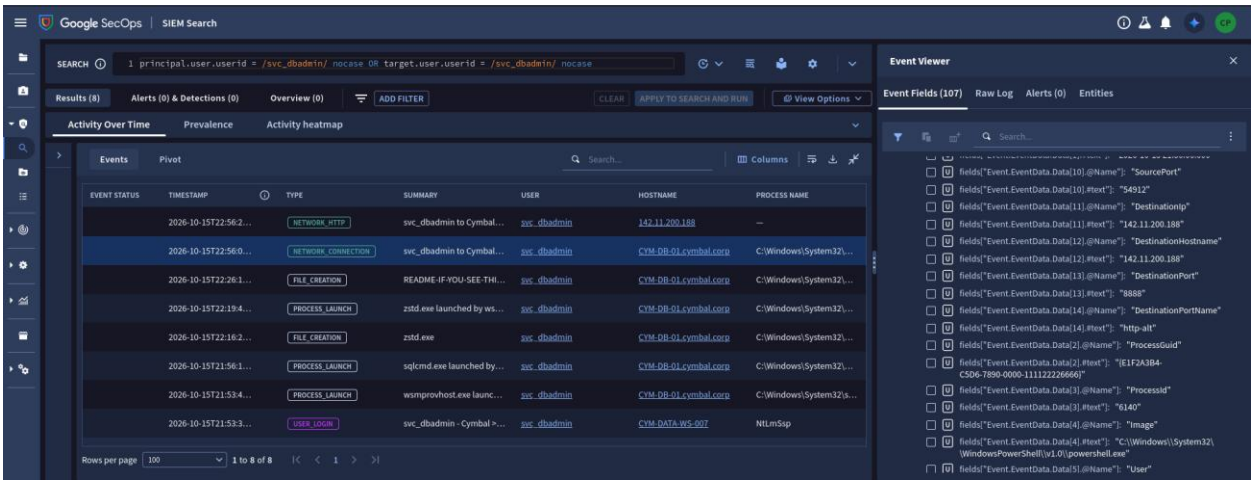
Yang ditanya terkait URL lengkap berisi IP, port, path, dan nama file.

Dalam proses pencarian URL ini harus dirangkai dari tiga log, karena masing-masing hanya memberi sebagian:

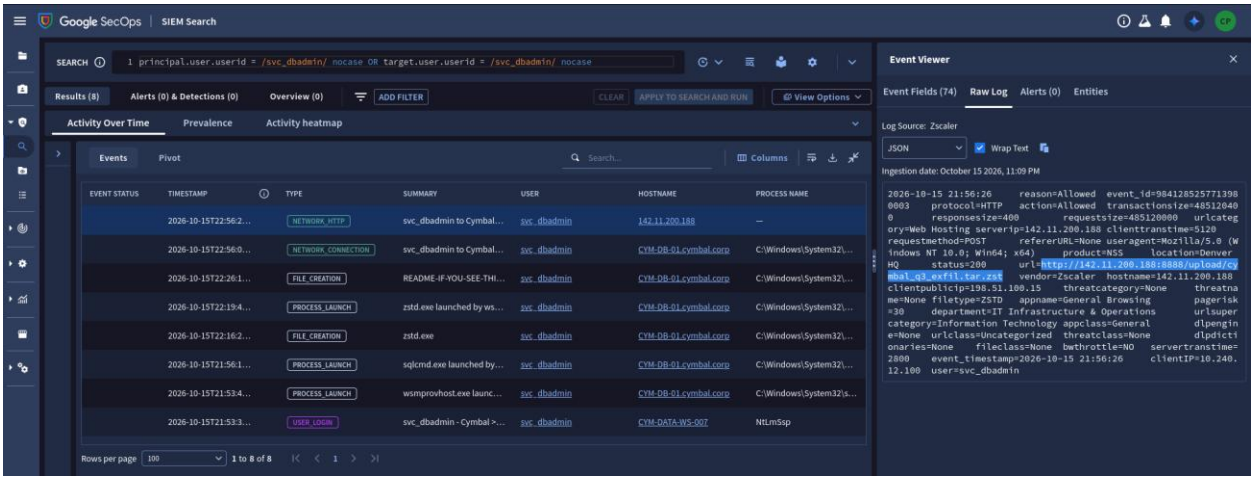
Query yang digunakan ini masih sama kayak sebelumnya, disini terdapat zstd.exe yang Dimana itu Sysmon EID 1, dari log tersebut didapat sebuah file .zst maka kita cata terlebih dahulu nama filenya.



Yang kedua kita cek Connection disitu terdapat Alamat IP dan PORT, jadi kita mendapatkan Alamat ip, port dan nama file, tetapi kurang 1 yaitu nama path



Yang ketiga kita lihat bagian Zscaler proxy (NETWORK_HTTP), cek dari lognya dan ternyata disana ada url lengkapnya yaitu ip, port, path, dan dile .zst itulah flagnya.



Flag6: http://142.11.200.188:8888/upload/cymbal_q3_exfil.tar.zst

Rogue Synthesis

Cymbal Investments' Threat Hunting team has received an intelligence bulletin regarding AI threats. Armed with Google Threat Intelligence (GTI) reporting and Google SecOps SIEM, your mission is to hunt down the initial compromise and identify the adversary's ultimate target in our CI/CD pipeline.

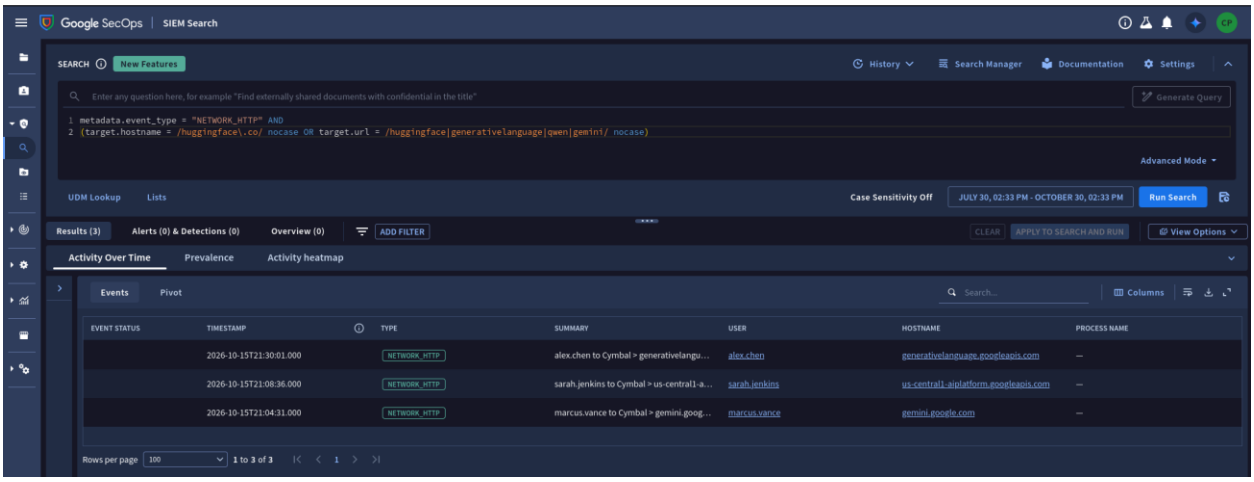
Q1. What developer username initiated a request to the model used by our AI threat? (expected format: user.name)

Di pertanyaan pertama ini ditanya siapa yang mengirim request ke ai model, jadi yang perlu diperiksa Adalah traffic http ke endpoint ai model:

Query:

```
metadata.event_type = "NETWORK_HTTP" AND
(target.hostname = /huggingface\.co/ nocase OR target.url = /huggingface|generativelanguage|qwen|gemini/ nocase)
```

Disini ada 3 user yang mengirim request tetapi jawabannya yang paling atas yang alex.chen



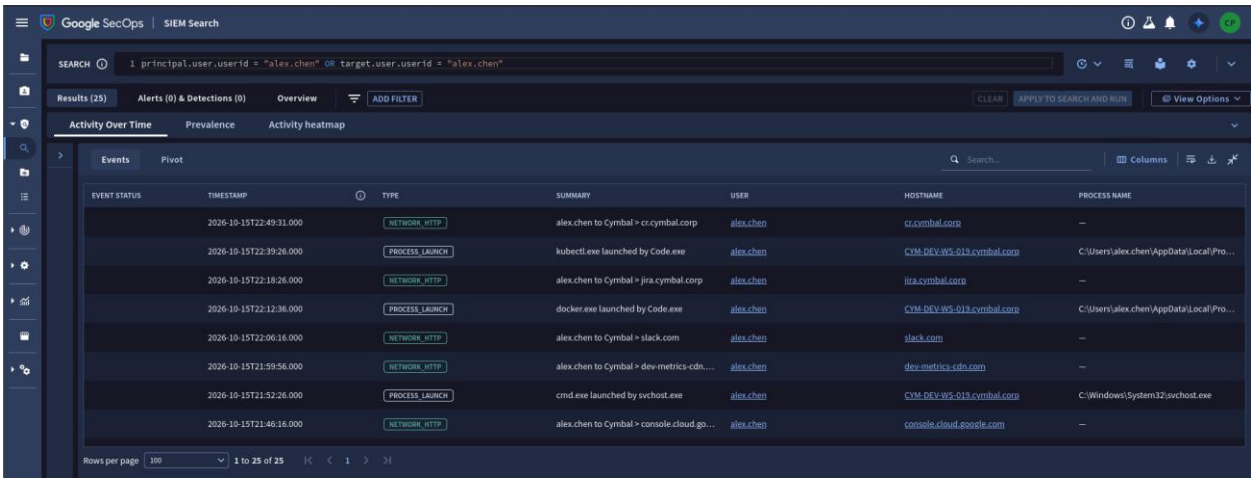
Flag1: alex.chen

Q2. What package was downloaded immediately prior to the API query? (expected format: File_Name.extension)

Query:

```
principal.user.userid = "alex.chen" OR target.user.userid = "alex.chen"
```

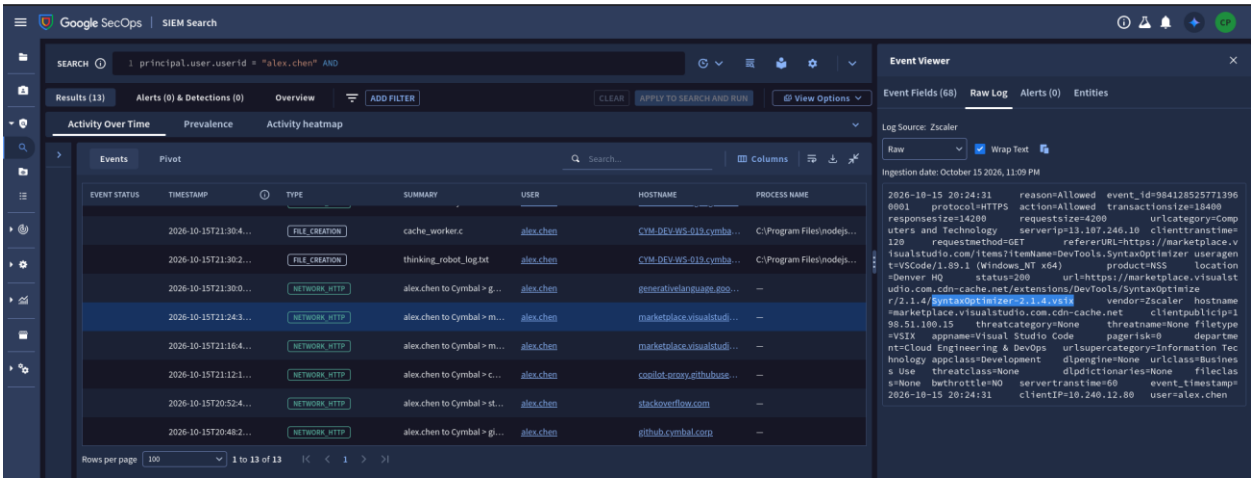
awalnya mengunakan query diatas tetapi muncul 25 log, jika dicek satu satu maka akan menghabiskan waktu jadi kita bikin query yang lebih spesifik.



Query 2:

```
principal.user.userid = "alex.chen" AND
(metadata.event_type = "NETWORK_HTTP" OR metadata.event_type = "FILE_CREATION" OR metadata.event_type = "NETWORK_CONNECTION")
```

Disini terlihat ada log mencurigakan karena domain tiruan yang hanya diawali nama marketplace asli, dan akhirnya flag kedua didapat.



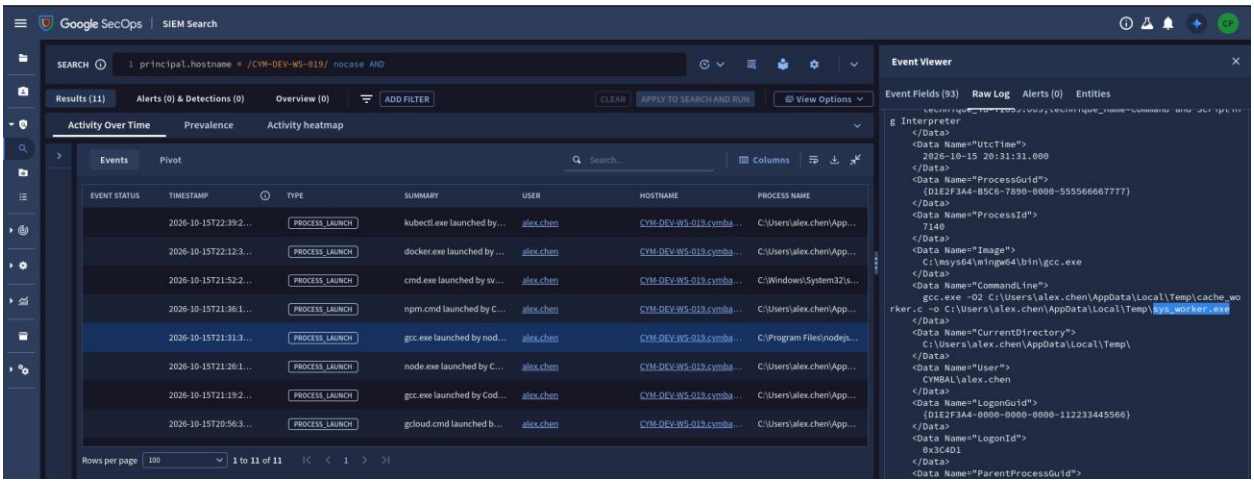
Flag2: SyntaxOptimizer-2.1.4.vsix

Q3. Following the outbound API request, what compiled executable was dropped into the local directory used by the malware for staging? (expected format: file_name.extension)

Awalnya ngecek dari log sebelumnya ada yang event yang mencurigakan di jam 21:30 tetapi ternyata isinya hanya file cache_worker.c itu Adalah file source code C, sedangkan yang ditanya file compiled executable.

Query:

```
principal.hostname = /CYM-DEV-WS-019/ nocase AND
metadata.event_type = "PROCESS_LAUNCH" AND
target.process.command_line = /cache_worker|gcc|cl\.exe|tcc|clang|\.exe/ nocase
```



Boom disini ada event yang dicari yaitu jam 21:31 disini kita cukup mencari data yang mengandung command line gcc dan disana terdapat file executable, itulag flagnya.

Flag3: sys_worker.exe

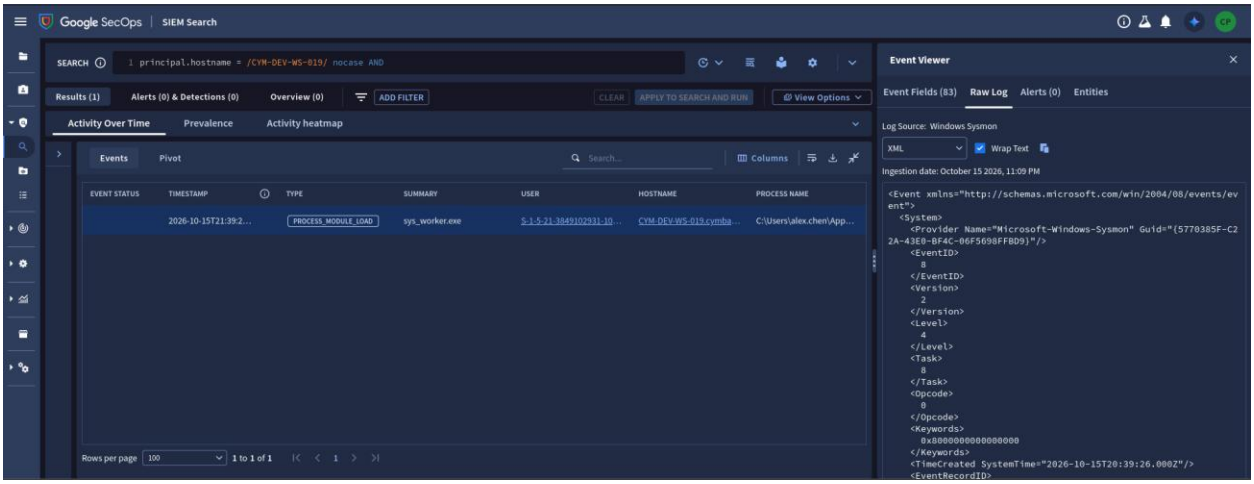
Q4. After elevating privileges via process hollowing on the developer's workstation, what existing file in the user's local cloud SDK configuration directory was read by the injected process to harvest tokens? (expected format: file_name.extension)

Langkah pertama yang dicari Adalah proses yang di hollow

Query:

```
principal.hostname = /CYM-DEV-WS-019/ nocase AND
(principal.process.file.full_path = /sys_worker/ nocase OR target.process.file.full_path = /sys_worker/ nocase)
```

Disini terlihat hak akses naik dari alex.chen ke SYSTEM melalui svchost.exe PID 624. Jadi kita cek dari PIDnya



Jadi kita cari aktivitas di PID 624

```
principal.hostname = /CYM-DEV-WS-019/ nocase AND
principal.process.pid = "624"
```

Di log terlihat ada proses hasil injeksi menjalankan cmd.exe untuk membaca database kredensial gcloud milik alex.chen. dan flagnya ketemu



Flag4: credentials.db

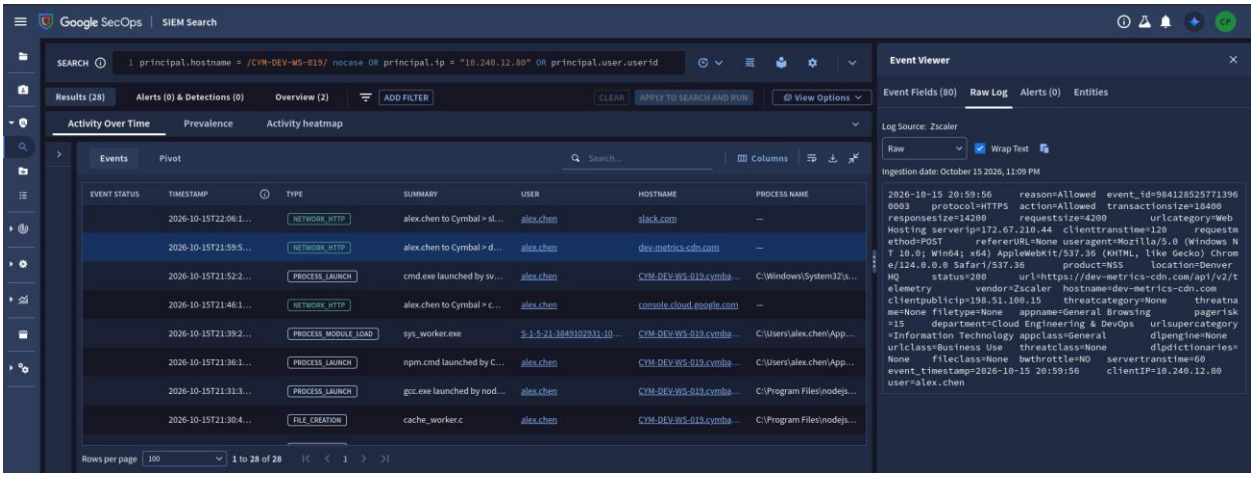
Q5. Shortly after the local tokens were harvested on the workstation, the stolen data was exfiltrated via an outbound HTTP POST request to an external URI path masquerading as a telemetry endpoint. To what external domain was the data sent? (expected format: domain-name.com)

tak lama setelah token dicuri (21:52:26), data dikirim lewat HTTP POST ke path yang menyamar sebagai telemetry. Di timeline alex.chen ada kandidat kuat: 21:59:56

Query:

```
principal.hostname = /CYM-DEV-WS-019/ nocase OR principal.ip = "10.240.12.80" OR principal.user.userid = "alex.chen"
```

Dengan prompt diatas terlihat terdapat 28 log disini kita cari, dan disalah satu log terdapat log yang mencurigakan pvent 2026-10-15 21:59:56: alex.chen to Cymbal > dev-metrics-cdn.com ini event yang cocok sama sebelumnya terjadi 7 menit setelah credentials.db, dan flag akhirnya telah didapat.



Flag bisa diliat di hostname.

Flag5: dev-metrics-cdn.com

Q6. Using the harvested service account to pivot laterally from the developer's workstation to a secondary server, what PowerShell script was overwritten by the attacker via PowerShell to establish persistence? (expected format: file_name.extension)

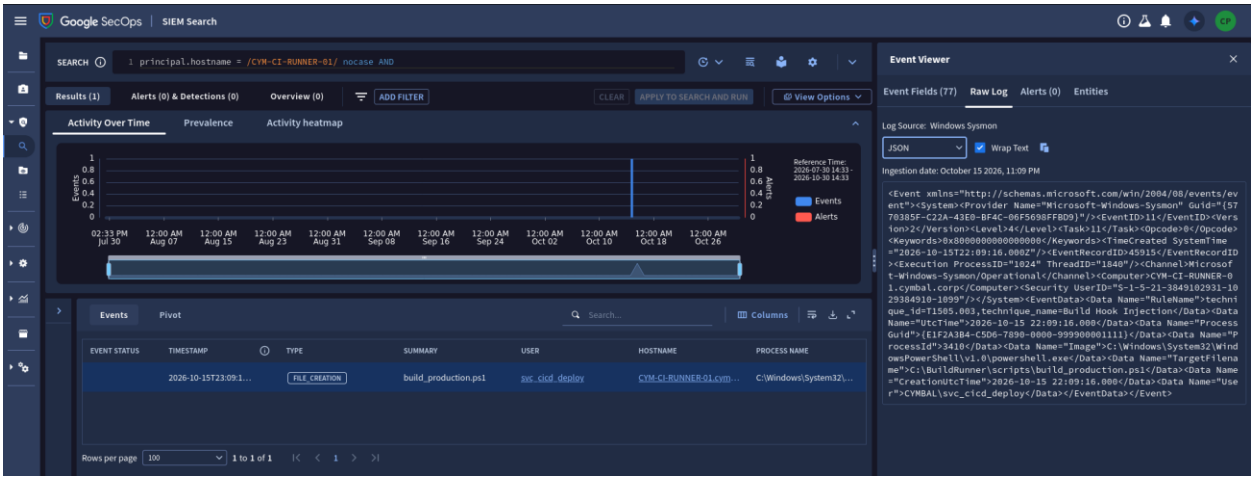
Flag terakhir ini, kita diminta men carifile .ps1 yang ditimpa di CYM-CI-RUNNER-01

Tidak perlu bingung, kita langsung keintinya mencari file .ps

Query:

```
principal.hostname = /CYM-CI-RUNNER-01/ nocase AND
target.file.full_path = /\.ps1$/ nocase
```

hanya terdapat 1 log, kita cek dan disana ada file .ps1 yaitu flag itu sendiri



Flag6: build_production.ps1